LABORATUVAR 4 · ARMA MANTAR BARİYER · KİMYA TESİSİ GİRİŞİ

Secure Remote Access

Çıktı: Secure Architecture

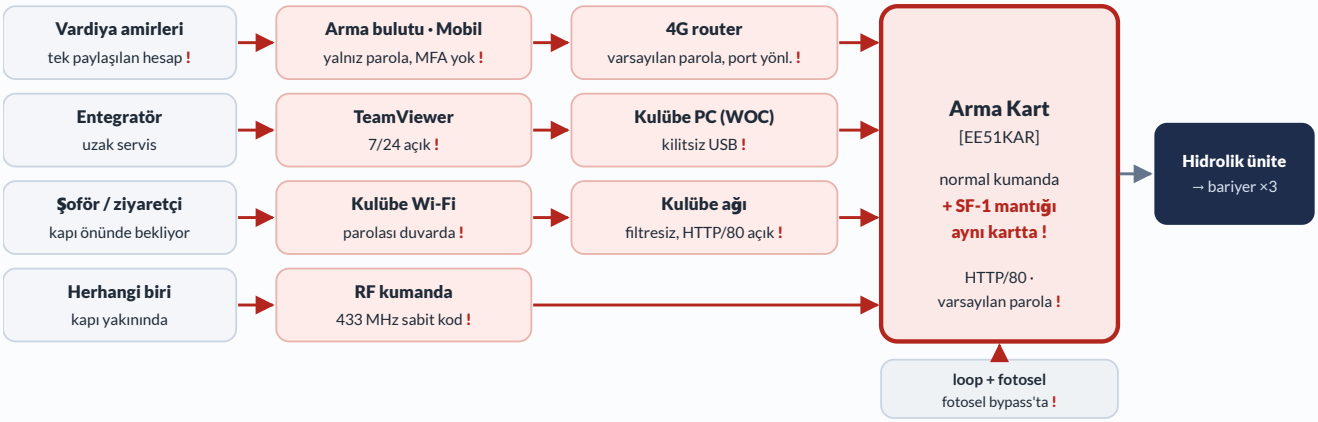
Ad Soyad Mehmet Onur Boyraz · 245541023 | Grup | Tarih 19.10.2026

> **Kavram:** İki katman var ve ikisi de şart. **Erişim güvenliği** girişi zorlaştırır: ara nokta, şifreli tünel, MFA + kişisel hesap, kayıt, varsayılan kapalı. **Emniyet bağımsızlığı** ise saldırgan içeri girse bile insanı korur. Bu makinede ikinci katman, LAB 1'deki SF-1'dir.

Görev A — mevcut → hedef

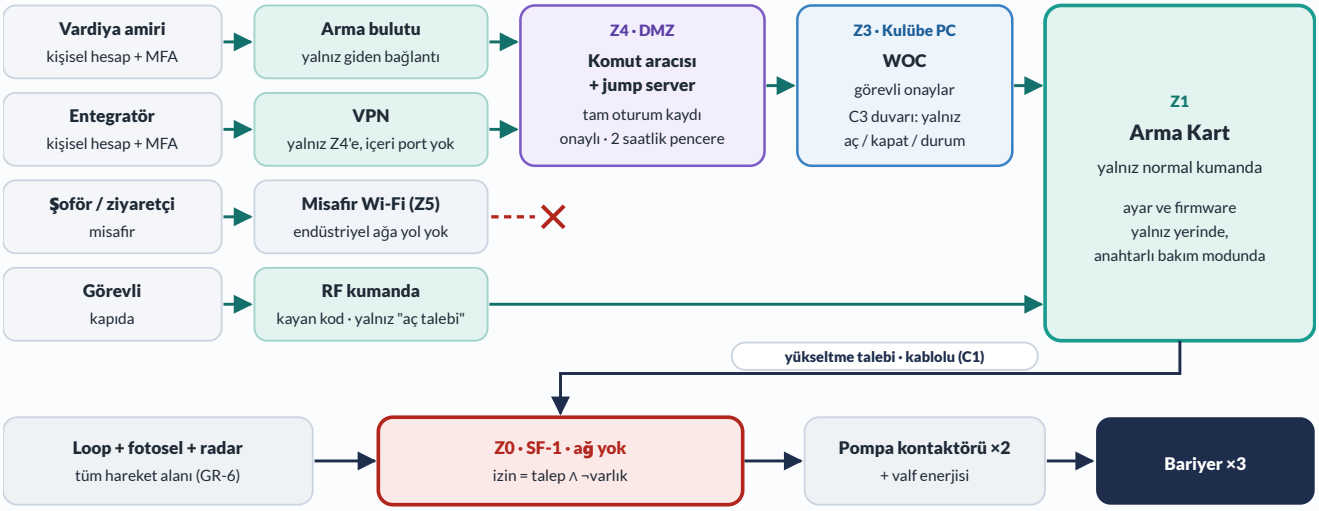
MEVCUT (bugün) V

İpucu: Arma Mobil bugün 4G router üzerinden Arma Kart'a **DOĞRUDAN** ulaşıyor ve SF-1'in mantığı da aynı kartta. Dört yolun dördü de filtresiz.



HEDEF (beş ilkeyle yeniden tasarım)

Her dış yol önce Z4'te sonlanıyor; Arma Kart'a yalnız izinli komutlar ulaşıyor. Hiçbir komut, Z0'daki SF-1'in izni olmadan bariyeri hareket ettiremiyor.



— izinli, kontrollü yol · ✕ yol yok · — emniyet zinciri. Arma Kart yalnız "yükseltme talebi" gönderebilir; kararı Z0'daki SF-1 verir.

Beş ilke bu makinede nasıl uygulandı?

İlke	Bugün V	Hedef	Kapattığı risk
1 · Ara nokta	TeamViewer kulübe PC'sine, 4G Arma Kart'a doğrudan	Z4'te jump server + mobil komut aracısı; hiçbir dış oturum Z1 ya da Z3'e doğrudan değmez	S1 · S3
2 · Şifreli tünel	4G router'da port yönlendirme	VPN yalnız Z4'e; Arma bulutuna yalnız giden bağlantı; içeri hiçbir port açık değil	S1 · R4
3 · Kimlik	Tek paylaşılan hesap, yalnız parola	Herkes kendi hesabıyla + MFA. Ayrılan personelin hesabı aynı gün kapanır; servis hesabı bir kişiye bağlıdır	S1
4 · Kayıt	Yok	Tam oturum kaydı (video + komut). Her bariyer komutu kullanıcı, zaman ve kaynakla kaydedilir; kayıtlar güvenlik merkezinde, silinemez depoda tutulur (LAB 6'nın kanıtı)	S1 · S3
5 · Varsayılan kapalı	7/24 açık	Servis erişimi: talep + vardiya amiri onayı + 2 saatlik pencere, sonra otomatik kapanır. Mobil "aç" isteği görevli onaylamadan geçmez	S1 · S3
+1 · Yetki kapsamı	Uzaktan tam yetki (aç, kapat, ayar)	Uzaktan yalnız "aç talebi" ve rapor. Ayar ve firmware yalnız yerinde, anahtarlı bakım modunda (LAB 2)	R4
2. katman · Emniyet bağımsızlığı	SF-1 Arma Kart'ta, uzaktan ulaşılabilir	SF-1 Z0'da; ona giden hiçbir ağ yolu yok. Her komut, kaynağı ne olursa olsun varlık algılamayla VE'lenir (LAB 1)	S1 · R4 · S3

Kavram kutusundaki altı başlığı beş ilkeye indirdik: MFA ile kişisel hesap tek bir "kimlik" ilkesi altında. RF kayan kod ve Wi-Fi'nin Z5'e taşınması uzaktan erişim değil ama şemada aynı mantıkla kapatıldı.

Görev B — functional safety köprüsü

1 **Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?**

> **Hedef mimaride: HAYIR — insan korunur.**
>
> 1. **Ulaşamaz:** SF-1 Z0'da ve hiçbir ağa bağlı değil. Ayarlarına uzaktan ulaşılamaz, firmware'i uzaktan değiştirilemez.
> 2. **Komut ≠ hareket:** içeri giren saldırgan en fazla bir "yükseltme talebi" üretebilir. SF-1 bu talebi varlık algılamayla VE'ler; hareket alanında insan ya da araç varsa bariyer kıpırdamaz.
> 3. **Bakım ve yeniden başlatma:** bakım modunda uzaktan gelen her komut reddedilir; enerji ya da iletişim gidip gelince bariyer kendiliğinden yükselmez (SF-3).
>
> **Dürüst sınırlar:** (a) **Güvenlik** yine de etkilenebilir: saldırgan bariyeri indirtebilir. Bunu emniyet değil sas kilidi ve görevli onayı karşılar. (b) SF-1 yalnız algıladığı kadar korur; algılama alanında bir boşluk varsa saldırgan o boşluğu kullanır (GR-6). (c) **Bugünkü mimaride: EVET** — SF-1'in mantığı uzaktan ulaşılabilen Arma Kart'ta V.

Bu mimarinin LAB 3 risklerine etkisi

Risk	LAB 3 skoru	Hedef mimaride	Ne değişti?
S1	27 · Kritik	**9** · Yüksek	Paylaşılan hesap, açık port ve doğrudan yol kalktı (L 3 → 1). Kalan 9, insan maruziyetinin (E = 3) sonucu.
R4	18 · Kritik	**9** · Yüksek	Wi-Fi Z5'te; SF-1 ayarlarına ağdan ulaşılamıyor (L 2 → 1).
R5	18 · Kritik	**6** · Orta	Bu föyün değil, sas kilidinin etkisi: emniyet tetiklense de iki hat birden inmiyor.
S2	12 · Yüksek	**6** · Orta	RF kayan kodlu ve yalnız "aç talebi" taşıyor; sas kilidi ikinci engel.
S3 ⚑	3 · Düşük ⚑	**3** ⚑	Skor aynı, ama yol kapandı: TeamViewer yok, USB kilitli, bakım modu uzak komutu reddediyor. Bayrak emniyet testleriyle kapanır.

Hiçbir satırda S değişmiyor: erişim güvenliği olasılığı düşürür, şiddeti düşürmez. Şiddet karşısında insanı koruyan tek şey ikinci katman, yani SF-1'dir.

2 **SF-1'in (varlık algılanınca yükselme engeli) uzaktan erişim yollarından etkilenmemesi için GEREKSİNİMİ yazın (çözümü değil).**

> Gereksinimler "ne olmalı" sorusunu cevaplıyor, "nasıl yapılır"ı değil. Her biri test edilebilir ve LAB 3'teki bir riske bağlı.

ID	Gereksinim	Risk	Nasıl doğrulanır?
GR-1 Bağımsızlık	SF-1'in kararı, normal kumanda sisteminden ve tüm uzaktan erişim yollarından bağımsız bir mantıkta verilmelidir. Bu mantık hiçbir ağ arayüzü üzerinden yapılandırılamamalı, devre dışı bırakılamamalı ve güncellenememelidir.	S1 · R4	İnceleme + port taraması: SF-1 tarafında açık ağ arayüzü bulunmamalı
GR-2 Komut kapısı	Kaynağı ne olursa olsun (yerel buton, WOC, Arma Mobil, RF, YZ, yangın sistemi) hiçbir yükseltme komutu, SF-1 izin vermeden hareket üretmemelidir.	S1 · S2	Test: algılama alanı doluyken her kaynaktan komut gönder → hareket olmamalı
GR-3 Değişiklik kontrolü	SF-1 parametrelerindeki (algılama hassasiyeti, gecikme, bypass) her değişiklik yalnız yerinde, yetkili bir kişi tarafından ve fiziksel bir izinle yapılabilmelidir. Değişiklik kaydedilmeli; ardından fonksiyon testi zorunlu olmalıdır.	R4	Denetim: her değişiklik kaydının karşısında bir test kaydı olmalı; parametre imzası (CRC) referansla aynı olmalı
GR-4 Bağımsız güvenilirlik	SF-1'in PLr = e seviyesi, ağın, bulutun, mobil uygulamanın ya da kulübe PC'sinin arızalanması veya ele geçirilmesi durumunda da korunmalıdır.	tümü	Analiz: SF-1'in tehlikeli arıza yollarında (FMEA) hiçbir BT bileşeni yer almamalı
GR-5 Güvenli yeniden başlama	İletişim kaybı, enerji dönüşü ya da kontrol sisteminin yeniden başlaması bariyerin kendiliğinden hareket etmesine yol açmamalıdır.	S3	Test: güç kes-ver, ağ bağlantısını kopar → hareket olmamalı
GR-6 Kapsama	SF-1'in algılama alanı, bariyerin hareket hacminin tamamını ve bu hacimdeki araç, yaya, bisikletli ve motosikletliyi kapsamalıdır.	S1 · R4	Test: yaya maketi ve bisiklet her konumda algılanmalı
GR-7 Bakım modu	Bakım modundayken uzaktan gelen hiçbir komut hareket üretmemelidir. Bakım modu yalnız yerinde ve fiziksel olarak açılıp kapatılabilmelidir.	S3	Yıllık tatbikat: bakım modunda WOC ve Mobil'den komut → hareket olmamalı

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Görev B'deki maddeler "ne olmalı" sorusunu cevaplar. Hangi cihazla, hangi mimariyle karşılanacağı üreticinin ve entegratörün tasarım kararıdır.

G üreticinin sitesinde yazan bilgi · V eğitim senaryosu varsayımı, **Arma ürünü hakkında iddia değildir**. Dayanaklar: IEC 62443-3-3 (SR 1.1 kullanıcı kimlik doğrulama · SR 1.13 güvenilmeyen ağlardan erişim · SR 2.6 uzak oturum sonlandırma · SR 2.8 denetlenebilir olaylar · SR 5.1–5.2 bölümleme ve bölge sınırı) · IEC TR 63069 (güvenlik önlemleri emniyet fonksiyonunu bozmamalı) · ISO 13849-1:2023 · AB Makine Yönetmeliği 2023/1230 Ek III 1.1.9 ve 1.2.1.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.